Edge trust: verified service token and one identity header

Report of the work done on branch feat/gateway-api, 1 and 2 October 2026

Status	Done, committed and merged. Not pushed.
Commit	`5aebb167` on `feat/gateway-api`, 48 files, 1321 lines added, 176 removed
Merge	Fast-forwarded into `announce-jo-branch` on 2026-10-02. `origin/announce-jo-branch` is one commit behind.
Scope	Three follow-ups of the customer edge: backends verify the service token, announce-management reads the owner from `X-User-Id`, and a deprecated configuration key is renamed.
Tests	224 tests in the seven touched modules pass in one Maven run. A manual check through a locally running edge passed.

1. Where the session started

The task block of the `gateway-api` worktree in CLAUDE.md was already implemented and merged. This was confirmed first: the branch was clean, the old `gateway` module was gone, and the acceptance tests of the customer edge and its single-page application passed.

The branch was then fast-forwarded to `announce-jo-branch` to pick up two newer commits (English seed data, Kafka on host port 9094). You chose three of the open follow-ups, a plan was written, and you approved it with two decisions: CLAUDE.md may be edited, and the admin edge header mismatch stays with the `gateway-admin` worktree.

2. The problem that was closed

- **Backends trusted identity headers from anyone.** The edges signed proxied requests with `X-Service-Token`, but no backend checked it. Anyone who could reach port 8085, 8083 or 8086 could send `X-User-Id` and act as that member.
- **The two edges signed differently.** The customer edge and the admin edge used different token layouts and different secret variables, so no single check could accept both.
- **A member could pose as staff.** The customer edge did not remove a client-supplied `X-Staff-Id`, and the messaging service prefers that header. This was found by reading the code; it was not exploited.
- **Two headers for one fact.** The customer edge copied `X-User-Id` into `X-Seller-Id` because announce-management only read the second one.

3. What was built

The token

Both edges now mint the same token, with one shared secret `ANNOUNCE_SERVICE_SECRET`:

```
X-Service-Token = v1.<service>.<epochSeconds>.<hex hmacSha256(secret, service + ":" + epochSeconds)>
```

One test vector is asserted in three places (the framework and both edges), so the layout cannot drift apart silently. The token only proves that a request passed a holder of the secret. It is not bound to the request and expires after 60 seconds.

The check in the backends

The framework module `cqrs-reactive` has a new `security` package, switched on per service with `announce.service-token.mode`:

Mode	Behaviour
`off`	No check. Used by the test profiles and by a service run on its own.
`log`	The token is checked and a failure is logged, but the request is served. For rolling the check out.
`enforce`	A missing, stale or forged token is answered 401 as a problem detail. `/actuator/**` stays open. Covers WebSocket handshakes.

announce-management, order and messaging ship with `enforce`. The messaging service signs its own lookup call to announce-management; that outbound signing is opt-in per client so the token never reaches the search tier.

Identity rules in announce-management

Routes	Rule
`/api/announces` writes	`X-User-Id` with `X-User-Type=MEMBER`. 401 without an id, 403 for another type.
`/api/announces` reads	The same pair identifies the viewer, so owners see their drafts. Anyone else is a visitor.
`/api/admin/announces/**`	`X-User-Id` with `X-User-Type=ADMIN` on every route. 401 without an id, 403 for a member.

`X-Seller-Id` is ignored everywhere and the edge filter that produced it is deleted.

Changes per module

Module	Change
cqrs-reactive	New `security` package: token class, inbound web filter, outbound signer, properties, auto-configuration. Client factory can sign calls per client.
cqrs-reactive-test	New helper `EdgeRequests` that signs a test suite's requests like an edge.
gateway-api	Strips `X-Staff-Id`, `X-Admin-Id`, `X-Seller-Id` and `X-Service-Token` from clients. `SellerHeader` route filter deleted. Secret variable renamed. Deprecated key `spring.codec.max-in-memory-size` renamed.
gateway-admin	Token minting aligned with the customer edge. Nothing else.
announce-management	New `Callers` helper; both announce controllers use it. Enforcement on. The `prod` profile refuses to start without the secret.
order	Enforcement on.
messaging	Enforcement on. Its announce lookup client signs its calls.
Docs and config	`doc/frontend-edges.md` section 10, `doc/cqrs-reactive.md` section 5a, two context docs, the gateway-api README, `docker/docker-compose.yml`, and CLAUDE.md (three header mentions and one build fact).

4. Verification

Automated tests

One Maven run over the seven touched modules, without the `webapp` profile:

Module	Tests	Result
gateway-api	21	pass
cqrs-reactive	54	pass
cqrs-reactive-test	15	pass
announce-management	59	pass, one skipped (a listing-import test not touched by this work)
order	33	pass
messaging	21	pass
gateway-admin	21	pass
Total	224	no failures

The end-to-end suites of announce-management, order and messaging now run with enforcement on. Each asserts that an unsigned request is refused; the messaging suite also asserts that an unsigned WebSocket handshake is refused. The customer edge's route tests assert that spoofed staff headers and a client's own service token never reach a backend.

Manual check

announce-management and the customer edge were started locally from this branch, with the file import and the scheduled jobs switched off, against the live MySQL database and the `docker/cqrs` stack:

Step	Result
Direct call to announce-management on 8085, no token	401
Direct call with admin identity headers but no token	401
Direct call with an old token signed with another secret	401
Direct post with member identity headers but no token	401
Direct health check	Answered, not 401 (reports DOWN because of the legacy Redis probe, as before)
Public listing through the edge, anonymous	200
Post through the edge, not signed in	401
Register and log in through the edge	201 and 200 (member 26)
Post a draft through the edge while sending spoofed id and type headers	201, stored under member 26
Owner reads and lists the draft through the edge	200, one draft
Visitor reads and lists the same draft	404, none
Admin announce API through the customer edge as that member	404, not routed

5. What you need to do or know

- **Clean announce-management once per checkout.** A `target/` directory built before this commit holds an empty copy of the `prod` configuration, and the build then fails with `copy-resources failed: newPosition < 0`. The main checkout has this stale file. Run the command below once.

```
mvn -pl announce-management clean
```

- **Direct calls to backends now fail.** A request to 8085, 8083 or 8086 gets 401. Go through an edge, or start the service with `--announce.service-token.mode=off`.
- **Build with the framework in the reactor.** The shared local Maven repository holds an older `cqrs-reactive` without the new package. Use `-pl cqrs-reactive,cqrs-reactive-test,<module>`.
- **Deploy order.** announce-management must go out before or together with the customer edge, and every service needs the same secret. Starting the backends in `log` mode first avoids a window of 401 answers.
- **Not pushed.** `announce-jo-branch` is one commit ahead of its remote.
- **Uncommitted file in the main checkout.** `open-fix-worktrees.sh` was already modified there before the merge. It was left untouched.

6. Open points

Point	Detail
Admin edge header mismatch	The admin edge forwards staff as `X-User-Id` with type ADMIN. The admin routes of order read `X-Admin-Id` and those of messaging read `X-Staff-Id`. The admin edge sets neither, so those routes do not work against the real backends. Left for the `gateway-admin` worktree, as you decided.
Failing test in db-reactive	`CustomReactiveMappersTest` needs a row in `announce_goods_product`, and the live table is empty. The module was not touched by this work.
One unexplained test failure	`MessagingEndToEndTest` timed out once waiting for its read model, in a run right after the order suite. It passed in the three later runs, including the final one. The cause was not found.
Merge with feat/messaging	Its unmerged commit touches the messaging configuration and end-to-end test that this work also edits. The edits are in different places, but the merge should be checked.
Admin listings endpoints	`/api/admin/listings/**` in announce-management has no caller check of its own. Only the service token protects it.
Data left in the dev database	Member 26 (`edgetrust_1001`) and one draft announce titled "Edge trust check (draft, safe to delete)". A draft cannot be withdrawn through the API.
Remaining follow-ups	Profile editing in the customer application, and a WebSocket mock for the chat screens.

Design record: `doc/frontend-edges.md` section 10 and `doc/cqrs-reactive.md` section 5a.